

AI-Enhanced Phishing Emails Targeting Small and Medium-sized Businesses: Unmasking the Threat and Building Defense

Ndubusi James Anyanwu
Georgia Institute of Technology
Nanyanwu3@gatech.edu

Abstract

In an ever-evolving digital landscape, Small and Medium-sized Businesses have become prime targets for sophisticated phishing attacks, that have been most recently augmented by AI. While generative AI is not new, the proliferation of open-source AI tools enables malefactors to craft deceptive emails with enhanced realism and precision. This report delineates the burgeoning threat landscape defined by AI-enhanced phishing attempts and introduces a comprehensive toolkit designed to fortify SMBs against these nefarious attacks. Through an iterative research methodology that encompasses various components such as the analysis of AI-boosted phishing mechanisms, prototype toolkit development, and empirical testing within real-world SMB settings, this paper distills actionable intelligence and robust countermeasures. The resultant toolkit comprises customized RWZ file configurations for email client security enhancement, a virtual machine set up for insulated examination of threats, and a meticulous hardening guide tailored for SMBs that are looking for a start in developing their cyber defense. Additionally, the report advocates for a collaborative defensive paradigm that is supported by shared intelligence and a dynamic rule list to foster a resilient collective immunity among SMBs. Feedback from pilot deployments illustrates the toolkit's efficacy and underscores areas for iterative refinement. This report culminates in a call for SMBs to adopt these defensive strategies, underpinning a collective vision for a fortified cybersecurity ecosystem resilient to counteract the evolving AI-phishing menace.

Keywords: Artificial Intelligence, Phishing Emails, Small and Medium-sized Businesses, Cybersecurity, Email Security, Threat Intelligence, Toolkit Development, Business Email Compromise, Defense Strategies, Cyber Threat Analysis.

1. Introduction

1.1 Background and Motivation

What is Phishing? Phishing is the deceptive approach to obtaining private information by pretending to be a trustworthy entity or organization and is currently undergoing a concerning evolution. What was once a rudimentary email scam has blossomed into a sophisticated menace, especially for Small and Medium-sized Businesses (SMBs). What was once thought to be an annoyance is turning out to be a sleeping giant awakening from its slumber. A recent report, SlashNext State of Phishing Report of 2023 [8], highlighted a staggering 1,265% surge in malicious phishing messages since the fourth quarter of 2022 in dangerous phishing messages. This shows a dynamic shift in how phishing emails are being used by threat actors. These figures do not just represent abstract statistics but instead, they represent a tangible and growing danger to SMBs, which are often looked at as the lifeblood of innovation and the economy when it comes to growth.



Diagram 1.

*The data indicates a significant increase in phishing attacks during 2023, reaching a peak of 600,000 incidents in March. Generative AI being released in November 2022
Data from apwg reports [9] [10] [11]*

The burgeoning role of artificial intelligence (AI) in phishing attacks marks a clear shift in cyber threats. The sudden integration of AI into phishing has armed cyber threats and cybercriminals with tools to craft messages with an unprecedented degree of realism as well as specificity, which can effectively sidestep traditional cybersecurity defenses and baselines. Reports have indicated a 967%[8]increase in credential phishing, with AI-powered techniques paving the way for more insidious forms of Business Email Compromise (BEC). This escalating threat is not lost on SMBs, who now face a more daunting task of fortifying their digital defenses against a new wave of AI-enhanced cyberattacks as well as dealing with traditional attacks. The best time for education in robust, accessible, and adaptive cybersecurity measures was yesterday, but today is a great time to start. This report delves into the evolution of phishing, draws on the latest statistical trends, and also examines how and why AI has become so pivotal in enhancing and creating new cyber threats, all with the aim to arm SMBs with the knowledge and tools to not just withstand but to anticipate and preempt the next generation of phishing attacks.

1.2 Importance of Cybersecurity for SMBs-

Why are SMBs so vulnerable to cyber threats? Small and Medium-sized Businesses (SMBs) often find themselves more vulnerable to cyber threats due to a combination of factors. First, the limited resources and budgets put SMBs in a position where they cannot heavily invest in advanced cybersecurity infrastructure or in-house expertise. This creates a gap which leaves them exposed to increasingly sophisticated cyber attacks, as this disadvantage is well-known by attackers. Additionally, SMBs often underestimate the likelihood of becoming targets, which leads to a much lower prioritization of cybersecurity measures.

The impact of cyber threats on SMBs is profound. A successful attack can threaten the very survival of a business, and even for businesses that do survive, they can still incur significant financial losses, damage to reputation, and loss of customer trust. The

aftermath of an attack often involves extremely costly clean-up efforts, which may include legal liabilities and the need to invest in substantial improvements in security measures. Moreover, the increasing reliance on digital tools and the internet for day-to-day business operations within companies only heightens the potential impact of such attacks due to an increased attack vector from ever-increasing digital access.

Given these vulnerabilities and the grave potential consequences that can follow, it is now more crucial than ever for SMBs to recognize the importance of cybersecurity in the way they conduct business. Implementing robust security measures, educating employees about not only emerging threats but also common cyber threats, and staying informed about the latest cybercrime trends, especially those specific to their industry, are essential steps in safeguarding their businesses. The advent of AI-driven attacks has accelerated the need for SMBs to adopt a proactive and comprehensive approach to cybersecurity, ensuring they are not merely responding to threats but also anticipating them so that potential risks can be mitigated or avoided.

1.3 Objectives of the Report

This report aims to provide a comprehensive analysis of the ever-escalating threat of AI-enhanced phishing attacks, particularly focusing on their impact against Small and Medium-sized Businesses (SMBs). The primary objectives are as follows:

1. Analyzing the Evolution of Phishing: To trace the development of phishing from the ever-present basic scams to the more sophisticated AI-driven threats in present day.
2. Assessing the Vulnerability of SMBs: To understand why SMBs are on the forefront of these cyber threats.
3. Evaluating the Impact of Cyber Threats on SMBs: To explore the financial, operational, and reputational consequences of such attacks on SMBs.
4. Exploring AI's Role in Phishing: To investigate how AI technology has transformed phishing capabilities and tactics, and how they have become more effective.

5. Developing a Comprehensive Toolkit for SMBs: To introduce and detail a toolkit designed with small businesses in mind to enhance the cybersecurity posture against these new AI-enhanced attacks.

6. Providing Actionable Strategies for SMBs: To offer practical and implementable strategies for SMBs to strengthen and harden their defenses against existing and evolving threats.

The expected outcomes of this report include a deeper understanding of AI-enhanced phishing threats, a detailed toolkit tailored for SMB defense, and actionable strategies that SMBs can use to bolster existing or non-existent cybersecurity measures.

1.4 Scope of the Research

This research paper focuses on an emerging threat of more effective phishing attacks targeting small businesses. The main focuses are the vulnerabilities of SMBs and the development of a toolkit and training to counter these threats.

The research begins by dissecting the evolution of phishing attacks from their emergence to the present day.

A portion of this research has been devoted to understanding why SMBs are particularly susceptible to these new advanced techniques.

The development of a defense toolkit/guide which could empower SMBs to fight against new AI-phishing attacks using readily available resources that have been tailored to fit their needs.

Examining the benefits of a Collaborative Cybersecurity Framework so that SMBs take a more collaborative approach to fighting common threats.

This includes the sharing of threat intelligence and the development of a dynamic rule list to enhance collective cybersecurity resilience.

2. Background

2.1 Understanding Phishing and Its Evolution

Phishing, a cybercrime that occurs when targets are contacted by email, telephone, or even text

message by someone pretending to be a legitimate institution or person to lure individuals into a false sense of security so that they can provide sensitive data, has evolved dramatically over the years. Initially, phishing attempts were relatively easy to spot in most mediums as they were most often characterized by poorly crafted messages and extremely blatant requests for personal information. However, like a seed introduced to water, as technology and tactics advance, the sophistication of these attacks has also grown into a formidable pest.

The evolution and origin of phishing can be traced back to the early and mid-1990s with the advent and creation of commercial internet use. Early phishing attacks were primarily focused on AOL users, as this was one of the most popular sites at the time, and attackers would often impersonate staff to steal passwords. While there is no official origin or group who claims the definition as their own, the term seems to have originated most likely from an analogy of “fishing” for hidden or confidential information.

With the proliferation of the internet and various online services, phishing attacks have grown in both frequency and complexity. In the early 2000s, phishing became a tool primarily used for identity theft. These types of attacks involved creating replicas of various banking websites to trick users into entering their credentials so that they could be stolen. As this persisted with the rise of spear phishing, a phishing in which specific individuals or organizations are targeted, using personal information to achieve a higher rate of success.

The last decade we have seen a drastic transformation in phishing techniques, which are mainly due to the various achievements and advancements in technology as a whole. The rise of social media and the abundance of easily accessible personal information has made it much easier for attackers to personalize and refine their attacks. You can imagine that before Facebook, your birthday wasn’t an easily searchable piece of information for strangers to find out. This era pushed phishing even further with the introduction of “whaling,” which is a term where high-profile targets are chosen, such as CEOs or high net worth individuals.

The use of AI and machine learning in recent years has further pushed phishing attacks, making them much harder to detect by traditional methods than

ever before. AI algorithms can now generate more convincing emails that mimic the style and tone of legitimate email traffic by analyzing various types of users. Additionally, AI can process vast amounts of stolen data, typically found on the dark web, to find potential victims to begin a successful spear-phishing campaign.

Your account has been compromised. Click here to reset your password.

Dear User,

We regret to inform you that your account has been compromised. For security reasons, please click the link below to reset your password.

[Reset Password]

Thank you,
The Management

Diagram 2

Subject: Urgent Action Required: Unusual Activity Detected on Your Account

Dear John Doe,

We've detected unusual activity on your account ending in 1982 that suggests a potential security breach. To ensure your account's safety, it's crucial that you verify your identity immediately.

Please follow the link below to confirm your account details and initiate a security review:

[Secure Verification Link]

For your protection, failure to complete this verification within 24 hours will result in temporary account suspension.

Thank you for your prompt attention to this matter.

Best regards,
Big Bank Security Team

Diagram 3 The differences between diagrams 2 and 3 are evident not only in the language used but also in the methodology. Dark Web hackers are known to purchase large amounts of user data. Utilizing AI, they can match the prefixes of account numbers to determine which bank a user is associated with. This information enables them to craft emails that appear more legitimate.

Reports such as the "APWG Phishing Activity Trends Report" [11] and the "Verizon Data Breach Investigations Report" [5] have documented the rise in phishing attacks. These reports not only highlight the increasing frequency of these attacks but also how their nature has evolved, with cybercriminals continuously adapting their strategies to bypass security measures and exploit human vulnerabilities.

The continuous arms race of phishing attacks poses a significant challenge to cybersecurity since it doesn't remain the same. Traditional defense mechanisms, which include spam filters and various antivirus software, are often inadequate in the face of complex AI-driven phishing attempts because of their uncanny ability to match real human users who have

various degrees of variability naturally in them. This calls for a shift in the approach in how we face phishing emails, with a focus on the importance of user education, advanced detection systems, and more proactive security measures.

In conclusion, understanding the origin of phishing and its evolution is crucial in the development of effective countermeasures because it shows the problem as a growing one, not a stagnant problem that can be solved once. This is a growing problem and as the problem evolves and as phishing techniques become more sophisticated, the need for comprehensive security strategies that include educational, technological, and procedural elements becomes even more important. The dynamic nature of phishing attacks requires constant vigilance and adaptation to ensure the protection of sensitive information and the prevention of identity theft as well as various forms of financial fraud that can occur with stolen data.

2.2 Current Frameworks

In cybersecurity, there exist various theoretical frameworks that can provide structured methodologies for assessing, managing, and stopping or mitigating cyber threats. These frameworks are pivotal in guiding organizations, including SMBs, in developing effective cybersecurity strategies.

NIST Cybersecurity Framework (CSF): Developed by the National Institute of Standards and Technology, the CSF offers a comprehensive approach to managing cybersecurity risks. It is built around five core functions: Identify, Protect, Detect, Respond, and Recover. This framework is very flexible and is used across many different sectors. [1]

ISO/IEC 27001: An international standard for information security management systems (ISMS), ISO/IEC 27001 provides a systematic approach for companies looking to manage their sensitive information. It includes a variety of risk management processes, security controls, and compliance measures. [2]

CIS Controls: The Center for Internet Security (CIS) Controls presents a prioritized set of actions to protect organizations and data from various cyber attack vectors. The main areas of focus are inventory and control of hardware and software assets, as well as

data protection and security training for employees. [3]

COBIT (Control Objectives for Information and Related Technologies): COBIT is a framework for developing, implementing, monitoring, and improving IT governance and management practices. It aligns business goals with IT goals and incorporates risk management and information integrity. [4]

MITRE ATT&CK Framework: This knowledge base is used as a foundation for the development of specific threat models and methodologies in the cybersecurity community. It provides a detailed understanding of tactics, procedures, and techniques used by cyber adversaries. [6]

Risk Management Framework (RMF): Developed by NIST, the RMF provides a process that integrates security and risk management in all development life cycles of the system to help manage security and privacy risk. [7]

When using these frameworks, organizations can assess their current security posture and enhance their defenses. These frameworks provide a basis for developing policies and ensuring compliance with regulatory standards.

For SMBs, aligning with these frameworks can lead to a more structured and effective approach to managing cybersecurity risks. And while the my toolkit does not directly follow one of these frameworks, the robust attention to detail and workflow was inspired by them.

3. Methodology

3.1 Development of the Toolkit

Elaboration on Conceptual Framework and Design Principles.

The development of this AI-Enhanced Phishing Detection Toolkit for SMBs was guided by a various robust conceptual frameworks as mentioned and design principles, to address the need for businesses working with less to be able to do more in combating phishing attacks as well as enhancing basic defense. The conceptual framework is as follows:

Risk Assessment First: The development first began with a risk assessment, so that I could identify the unique threats faced by SMBs in the realm of AI-enhanced phishing.

User-Focused Design: The toolkit was designed with a focus on the end-user experience, ensuring ease of use and accessibility for SMBs without extensive technical expertise so that any person or SMB could benefit from using it.

Adaptability and Scalability: Recognizing the dynamic nature of cyber threats, the toolkit was built to be adaptable to emerging phishing tactics and scalable to different business sizes and needs. The goal is to create baseline that can be understand by most SMBs and then further improved.

Design Principles:

Integration Capability: Designed to seamlessly integrate with existing IT infrastructure, minimizing disruption to business operations and to use tools that were open-source.

Comprehensive Coverage: The toolkit includes modules for detection, prevention, and response to phishing attacks, covering the entire threat lifecycle.

User Training and Awareness: Incorporating educational tools and resources to raise awareness and train staff on identifying and responding to phishing threats because the weakest link in phishing usually are end users.

Continuous Improvement: Embedding mechanisms for continuous feedback and updates through Google Forms to ensure the toolkit remains effective against evolving phishing techniques.

Collaboration with Cybersecurity Experts: Engaged with cybersecurity professionals to align the toolkit with industry best practices and the latest research findings in the development cycle.

Pilot Testing and Feedback Loop: Conducted pilot tests with select SMBs, gathering feedback to refine and optimize the toolkit to address not only phishing needs but also basic cybersecurity needs.

In conclusion, the development of the toolkit was a multi step process guided by these key design principles so that research would be actionable . At the end of day, the focus was on creating a user-friendly guide that empowers SMBs to proactively defend against emerging AI phishing attacks and be made aware of cyber threats.

3.2 Component Design

The AI-Enhanced Phishing Detection Toolkit for SMBs is comprised of several key components that aim to address specific aspects of the phishing threat landscape.

Security Baseline and Standards Module:

Functionality: Establishes robust security baselines and standards for SMBs.

Features: Guide on optimizing email platforms (Outlook) for maximum security, including regular updates and secure configurations.

User Customization: Allows SMBs to add or modify rules based on their specific needs.

RWZ File Configuration for Email Security:

Purpose: Enhances email client security by implementing rules for email processing.

Key Rules:

Mismatched Display Names and Email Addresses: Automatically deletes emails where the sender's display name and email address domain don't match.

Warning for External Emails: Appends a warning message to emails from outside the organization, with exceptions for trusted senders.

RWZ Rules Guide for AI-Enhanced Phishing Detection

Rule 1: Identify Suspicious Email Domains

Condition: Check messages when they arrive.
Criteria: Sender's domain is in the list of known dangerous domains.

Action: Move the email to a "Review" folder and send to VM.

Exception: None.

Rule 2: Flag Emails with Suspicious Attachments

Condition: Check messages when they arrive.

Criteria: Email contains attachments with risky file extensions (.exe, .scr, etc.).

Action: Move the email to "Quarantine" and flag for review.

Exception: Sender is in the Safe Senders list.

Rule 3: Detect Common Phishing Keywords

Condition: Check messages when they arrive.

Criteria: Subject line or body contains common phishing keywords (e.g., "urgent", "verify your account", "password reset").

Action: Alert user and move email to "Review" folder.

Exception: None.

Rule 4: Block Emails with Mismatched Display Names and Email Addresses

Condition: Check messages when they arrive.

Criteria: Sender's display name and email address domain don't match.

Action: Directly delete the email.

Rule 5: Warning for External Emails

Condition: Check messages when they arrive.

Criteria: Email is from outside the organization.

Action: Append a warning message at the top of the email body.

Exception: Sender's domain is on the trusted external senders list.

Section User Customization

Guidelines for SMBs: Customizing RWZ Files for Enhanced Phishing Protection

Initiating Rules Setup in Outlook:

Launch Microsoft Outlook.

Navigate to 'File' > 'Manage Rules & Alerts'.

Rule Creation Process:

Select 'New Rule'.

Option for 'Apply rule on messages I receive' found under 'Start from a blank rule'.

Criteria Specification for Phishing Detection:

At the 'Conditions' stage, pinpoint typical phishing indicators like 'specific words in the subject' or 'emails from outside my organization'.

Proceed to 'Next' for action specifications on detected messages.

Configuring Actions for Flagged Emails:

Options include 'moving to a specific folder' or 'deletion'.

Consider setting up flags for further review.

Finalization and Activation of Custom Rule:

Thoroughly review the rule's summary.

Assign a descriptive name like 'Phishing Detection for scams' for easy identification.

Confirm activation by checking 'Turn on this rule'.

Finalize by clicking 'Finish'.

Virtual Machine for Email Examination:

Objective: Provides a secure and isolated environment for analyzing quarantined emails in the form of kali Linux.

Advantages-

Isolation of Threats: Prevents potential malware in phishing emails from infecting the main system.

Controlled Testing Environment: Facilitates the detailed inspection of suspected phishing emails without compromising the SMB's primary systems.

Community-Sharing Platform for Threat

Intelligence-

Function: Creates a network for SMBs to share insights and updates on phishing threats.

Mechanism: Utilizes platforms like Google Forms to gather and disseminate feedback, fostering a collaborative approach to defense. The goal is to be able to be forwarded known phishing emails for further analysis.

```
1 #!/bin/bash
2
3 #network interface to monitor
4 INTERFACE="eth0"
5
6 # filter for email traffic (SMTP, IMAP, POP3)
7 EMAIL_FILTER="port 25 or port 143 or port 110"
8
9 # Run Wireshark in the background
10 wireshark -i $INTERFACE -k -f "$EMAIL_FILTER" -w email_traffic.pcap &
```

Diagram 4

This script is designed to monitor email traffic on a Linux system using Wireshark, a network protocol analyzer. It specifies the network interface (eth0) and sets a filter to capture traffic on SMTP, IMAP, and POP3 ports. Wireshark is then run in the background, capturing and then saved to pcap". This script helps in analyzing email communications for potential security threats.

```
1 #!/bin/bash
2
3 # Bash script to disable all network interfaces
4
5 for interface in $(ip -o link show | awk -F: ' '{print $2}')
6 do
7     sudo ip link set $interface down
8 done
```

Diagram 5

This script is a Bash command designed to disable all network interfaces on a Linux system. It iterates through each network interface identified by the ip command and uses sudo ip link set down to disable them. This was one of the hardening steps to ensure VM safety.

User Education and Awareness Resources:

Content: Provides educational materials and training simulations to enhance staff awareness about phishing that are already open source and on the web. Delivery: Multiple formats to ensure effective learning and retention.

Regular Updates and Adaptations:

Ongoing Refinement: Continuously updates the toolkit based on new findings and feedback from SMBs.

Response to Evolving Threats: Adapts to the ever-changing nature of AI-enhanced phishing attacks.

These are some trainings that SMBs can go to immediately that are trusted and verified. From 15-minute amazon course to public cyber mil awareness challenge it allows a great jumpstart to establish cyber awareness for SMBs

Amazon Cybersecurity Awareness Training

Overview: A concise 15-minute training covering secure communication, data classification, phishing, and more.

Suitability: Ideal for SMBs for quick and comprehensive cybersecurity upskilling.

Access: Available online for easy integration into employee training schedules.



Public Cyber.mil Awareness Challenge

Purpose: Annual basic cyber awareness challenge to maintain and update cybersecurity knowledge.

Relevance: Ensures employees are up-to-date with current cybersecurity threats and best practices, with a focus on phishing awareness.

Accessibility: Open for all and comprehensive.

3.3 Development Process

The development process of the AI-Enhanced Phishing Detection Toolkit for SMBs followed a structured implementation workflow, ensuring a methodical and efficient approach to meet the specific needs of SMBs in combating phishing threats.

Conceptualization and Needs Analysis:

Initial Phase: Identified the unique challenges faced by SMBs regarding AI-enhanced phishing.

Requirements Gathering: Conducted surveys and interviews with SMB representatives to understand their specific cybersecurity needs.

Design and Prototyping:

Tool Design: Created a blueprint of the toolkit, outlining its components and functionalities that it should have as well as needed research to create.

Prototyping: Developed a prototype based on the design, incorporating feedback from the conceptualization phase.

Collaboration with Cybersecurity Professionals :

Input: Engaged with Cybersecurity Classmates for feedback.

Pilot Testing and Feedback Collection:

Implementation in SMB Environments: Deployed the prototype in selected SMBs for real-world testing. This prototype came in the form of hands own interaction but with the intention that one day everything will be automated.

Feedback Mechanism: Utilized surveys and interviews to collect feedback on the toolkit's performance and usability.

Data-Driven Refinement:

Analysis of Feedback: Evaluated feedback and test results to identify areas for improvement.

Iterative Refinement: Made iterative enhancements to the toolkit based on the analysis.

Finalization and Release:

Final Development: Incorporated all refinements and prepared the toolkit for final release.

Updates:

Ongoing Support: Established a feedback loop for SMBs who want to use toolkit and methodologies when its complete .

Regular Updates: Developed a schedule for regular updates to the toolkit, ensuring it remains effective against evolving phishing threats.

The development process emphasized collaboration, feedback, and continuous improvement, resulting in a robust and user-friendly toolkit tailored to the specific cybersecurity needs of SMBs.

3.4 Tools and Technologies Used

Email Security Software: Email filtering and security tools were integrated into the toolkit and focused on outlook emails.

Network Analysis Tools (Wireshark): Wireshark, a widely-used open-source network protocol analyzer, was utilized to monitor and analyze network traffic. This tool helps in identifying suspicious activities and anomalies that could indicate phishing attempts and also generate pcaps for further analysis.

Virtual Machine Software: To safely analyze potential phishing threats, virtual machine software was used to create isolated environments. This setup allows for the examination of suspicious emails without risking the main system's integrity.

The combination of these tools and technologies forms the backbone of the toolkit, enabling it to effectively counter the sophisticated nature of AI-enhanced phishing attacks. The use of open-source tools like Wireshark also ensures that the solution remains accessible and adaptable for SMBs with varying levels of resources.

3.5 Collaboration and Stakeholder Engagement

The development of the AI-Enhanced Phishing Detection Toolkit for SMBs was marked by significant collaboration and stakeholder engagement, ensuring the tool effectively addresses the real-world needs and challenges of its users.

SMB Involvement: Actively involved SMB representatives in the development process to ensure the toolkit not only would met their specific

requirements but would be understood by them. Regular feedback sessions and pilot testing with SMBs were crucial in refining the toolkit.

Feedback and Surveys: Implemented a structured feedback mechanism, including surveys and interviews, to gather input from SMB users. This feedback was instrumental in iteratively improving the toolkit and finding out the needs of the SMBs.

3.7 Ethical Considerations

In developing the AI-Enhanced Phishing Detection Toolkit for SMBs, ethical considerations were paramount to ensure responsible interactions with client data.

Data Privacy and Confidentiality: The toolkit handles sensitive data, by keeping everything at the moment in house.

Transparency and Accountability: Maintained transparency about the toolkit's capabilities and limitations

User Consent and Autonomy: Ensured that SMBs have full control and consent over the implementation of the toolkit in their systems, respecting their autonomy in cybersecurity decisions.

Ongoing Monitoring and Assessment: Committed to regularly assessing the ethical implications of the toolkit as technology and cyber threats evolve, adapting as necessary to uphold ethical standards.

4. Evaluation

4.1 Testing Methodology

Real-world Scenario Testing: The toolkit was then deployed in real-world SMB settings in limited fashion. This phase aimed to evaluate the toolkit's performance under actual operating conditions, including its ability to handle real-time phishing attacks.

User Feedback Analysis: Feedback from SMB users who participated in the testing was collected and analyzed. This qualitative data provided insights into the toolkit's usability and effectiveness from the user's perspective.

On a scale of 1-5, how user-friendly do you find the toolkit?

1 2 3 4 5

How many false positives (legitimate emails flagged as phishing) have you encountered this week?

Short answer text

On a scale of 1-5, how helpful are the toolkit's user education and awareness resources?

1 2 3 4 5

How often do you use the community-sharing platform for threat intelligence? (Daily, Weekly, Monthly, Rarely, Never)

☐ Daily

☐ Weekly

☐ Monthly

☐ Rarely

☐ Never

Google forms questions from questionnaire

5. Results and Discussion

The implementation and testing of the RWZ rules proved to be a significant step forward, offering invaluable insights for further refinement. The SMBs responded positively to the training modules, appreciating the practical relevance and expressing keen interest in adopting the virtual machine (VM) setup for their in-house cybersecurity needs. This enthusiasm underscores the growing awareness and proactive stance of SMBs towards cybersecurity threats.

A key area of feedback concerned the automation of the VM. While SMBs appreciated the RWZ ruleset's ease of import, they desired a similar level of automation for the VM. There was a palpable concern that manual handling of flagged emails within the VM might still leave them vulnerable to infection. This feedback is instrumental in guiding future enhancements of the VM, aiming to balance user-friendliness with robust security measures.

The ongoing dialogue through Google Forms has been pivotal in fostering a dynamic, responsive, and user-friendly approach to cybersecurity. This iterative process is vital in creating a cybersecurity

ecosystem that is not only robust but also adaptable to the evolving needs and capacities of SMBs.

Interestingly, the fully hardened VM for testing emails garnered more interest from medium-sized businesses than small businesses, likely due to the perceived complexity of the system. This distinction highlights the diverse needs within the SMB sector and the importance of tailoring cybersecurity solutions accordingly.

6.Future Work

The journey to refine and automate the toolkit remains ongoing. My intention is to delve deeper into the realm of machine learning, with the aim of analyzing data received from SMBs more efficiently. The goal is to harness machine learning's predictive power to streamline the analysis process, thereby enhancing the toolkit's responsiveness and efficacy.

Additionally, a significant focus will be on automating the VMs to the greatest extent possible. This automation is not just about simplifying the user experience but also about ensuring that the security measures remain robust and effective. The end goal is to make the VMs more accessible and user-friendly, encouraging wider adoption among SMBs.

7. Conclusion

In this era where digital threats constantly evolve, this research has illuminated the growing menace of AI-enhanced phishing attacks targeting Small and Medium-sized Businesses (SMBs). Through a comprehensive exploration of the phishing landscape, from its rudimentary beginnings to its current AI-augmented complexity, this paper has not only highlighted the increased vulnerability of SMBs but also paved the way for practical, impactful defense strategies.

The need for a specialized toolkit tailored for SMBs in equipping these businesses with the necessary tools and knowledge to fortify their defenses was apparent. The toolkit, encompassing RWZ rule configurations, a virtual machine setup for secure email examination, and a suite of educational resources, stands as a testament to the potential of

well-crafted cybersecurity solutions in the fight against sophisticated cyber threats.

Feedback from SMBs has been instrumental in refining the toolkit, emphasizing the need for automation and ease of use, particularly in environments with limited cybersecurity resources.

The fight against AI-enhanced phishing attacks is not just about technological advancements; it's about fostering a culture of awareness, preparedness, and collective defense within the SMB community.

In closing, this paper calls upon SMBs to embrace these tools and strategies, thereby contributing to a more secure and resilient digital ecosystem capable of withstanding the ever-evolving threats of our digital age. I hope to one day bring everything I learned together to provide a free solution to all those who require it.

Limitations and Future Directions

The research acknowledges certain limitations, such as the rapidly evolving nature of AI technologies and phishing tactics. Future research directions include continuous refinement of the toolkit and exploration of new AI-driven cybersecurity threats. As we approach the first full year since introducing generative AI to the masses, I hope to gather more data. One major limitation was the lack of specific data, or data that was too general for practical use. Another interesting limitation, which I plan to investigate further, is that SMBs, especially very small businesses, had more pressing cyber concerns and a need for basic education in technological literacy. Overall, I am excited about the feedback and look forward to seeing the start of fully automated processes in the future

8. Acknowledgments

I would like to express my sincere gratitude to Dr. Mustaque Ahamad, Dr. Brenden Kuerbis, and Dr. Saman Zonouz for their invaluable guidance and insights throughout this project and courses.

Special thanks to the teaching assistants, Samir Ahmed and Creston Flemming, for their assistance and dedication.

I am also grateful to my university, friends, and family for their constant encouragement and support. A heartfelt acknowledgment goes to the small family

businesses that participated in data collection and provided initial feedback, choosing to remain anonymous.

Finally, I extend my deepest appreciation to my parents, Leo Anyanwu and Justina Anyanwu, for their unwavering love and support throughout this program. Your sacrifices and belief in my abilities have been the cornerstone of my success.

9. References

- [1] National Institute of Standards and Technology, "NIST Cybersecurity Framework (CSF)," [Online]. Available: <https://www.nist.gov/cyberframework>.
- [2] International Organization for Standardization, "ISO/IEC 27001," [Online]. Available: <https://www.iso.org/standard/54534.html>.
- [3] Center for Internet Security, "CIS Controls," [Online]. Available: <https://www.cisecurity.org/controls/>.
- [4] ISACA, "COBIT (Control Objectives for Information and Related Technologies)," [Online]. Available: <https://www.isaca.org/resources/cobit>.
- [5] Verizon, "2023 Data Breach Investigations Report," 2023.
- [6] MITRE, "MITRE ATT&CK Framework," [Online]. Available: <https://attack.mitre.org/>.
- [7] National Institute of Standards and Technology, "Risk Management Framework (RMF)," [Online]. Available: <https://www.nist.gov/risk-management>.
- [8] SlashNext, "The State of Phishing Report 2023," 2023.
- [9] Anti-Phishing Working Group, "APWG Trends Report Q1 2022," 2022.
- [10] Anti-Phishing Working Group, "APWG Trends Report Q2 2023," 2023.
- [11] Anti-Phishing Working Group, "APWG Trends Report Q1 2023," 2023.